

SIMATS ENGINEERING ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking

COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO4: *Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux.*

QUESTIONS: 01

Total Marks:100

Annexure A VULNERABILITY ASSESSMENT REPORT

Code of Conduct:

*I Aluri poojitha(192511230)_(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of the student:poojitha

S.No	Assessment Criterion	Excellent	Good	Satisfactory	Needs Improvement	Marks
1	Incident Background and Technical Understanding(20)	Clearly explains the incident, timeline, affected organization, threat actor, wireless technology, and attack context.	Explains most incident details with minor omissions.	Provides a basic incident summary but lacks technical depth.	Incident description is inaccurate, incomplete, or unclear.	
2	Identification of Wireless Vulnerabilities(20)	Accurately identifies vulnerabilities related to wireless standards, encryption, authentication, access points, configuration, and network architecture.	Identifies most major vulnerabilities with reasonable explanation.	Identifies only basic or obvious vulnerabilities.	Fails to identify important vulnerabilities or provides incorrect findings.	
3	Risk, Impact, and Root-Cause Analysis(20)	Provides a detailed analysis of attack vectors, root causes, affected assets, likelihood, and operational, financial, privacy, legal, and reputational impacts.	Provides a good risk and impact analysis with minor gaps.	Discusses general risks and impacts without sufficient justification.	Risk analysis is weak, irrelevant, or unsupported.	
4	Security Recommendations and Mitigation Measures(20)	Proposes practical and well-justified controls involving secure authentication, encryption, segmentation, monitoring, access control, policies, and user awareness.	Recommends appropriate controls with minor omissions.	Provides basic recommendations with limited technical detail.	Recommendations are impractical, incomplete, or unrelated to the identified risks.	
5	Report Quality, Evidence, and Presentation(20)	Report is well-structured, professionally written, supported by reliable references, diagrams, tables, and a clear risk-rating summary.	Report is clear and organized with suitable evidence and references.	Report is understandable but lacks organization, evidence, or proper referencing.	Report is poorly organized, unsupported, or contains major presentation errors.	
					Total	

Annexure A

1. TJX Companies Wireless Network Breach, 2005–2007

TJX Companies experienced a major payment-card data breach after attackers obtained unauthorized wireless access to its retail network. Investigations found that TJX had used WEP while transitioning to WPA and had not implemented adequate controls to restrict wireless access. The incident demonstrated the risks of obsolete encryption, inadequate monitoring, weak network segmentation, and insecure transmission of sensitive data.

Assignment Question: Prepare a Vulnerability Assessment Report examining the wireless encryption, authentication, network segmentation, monitoring, and payment-data protection weaknesses that contributed to the TJX incident. Recommend how WPA2/WPA3, enterprise authentication, rogue-access-point detection, and PCI DSS controls could have reduced the risk.

2. Lowe's Wireless Network Intrusion, 2003

In 2003, attackers compromised the wireless network of a Lowe's retail store in Southfield, Michigan. The compromised wireless connection provided access to the company's central systems and other retail locations. The attackers attempted to install software intended to capture customers' credit-card information.

Assignment Question: Prepare a Vulnerability Assessment Report identifying the weaknesses that allowed a local wireless compromise to create access to a nationwide corporate network. Assess authentication, wireless isolation, firewall controls, point-of-sale segmentation, intrusion detection, and centralized access management.

3. Firesheep and Public Wi-Fi Session Hijacking, 2010

The Firesheep browser extension demonstrated how attackers connected to the same open wireless network could capture unencrypted session cookies and impersonate authenticated users. The event highlighted the danger of websites encrypting only the login page while transmitting later session information without full HTTPS protection.

Assignment Question: Prepare a Vulnerability Assessment Report for a public Wi-Fi provider affected by Firesheep-style session hijacking. Assess open-network authentication, session-cookie protection, HTTPS enforcement, HSTS, VPN use, wireless client isolation, and user-security awareness.

4. DarkHotel Attacks Through Hotel Wi-Fi Networks

The DarkHotel campaign targeted business executives and government officials using compromised hotel networks. Selected guests connecting to hotel Wi-Fi were presented with fraudulent software-update prompts that delivered malware. The campaign demonstrated the risks associated with third-party Wi-Fi management, captive portals, insecure update mechanisms, and insufficient guest-network monitoring.

Assignment Question: Prepare a Vulnerability Assessment Report for the affected hotel environment. Examine guest authentication, captive-portal security, DNS integrity, network segmentation, third-party access, digital-signature verification, malware detection, and monitoring of privileged hotel-network systems.

5. Marriott Wi-Fi Deauthentication Incident, 2014

The United States Federal Communications Commission investigated Marriott after equipment was used to send Wi-Fi deauthentication messages that prevented guests from using their personal hotspots. Marriott agreed to pay a civil penalty of \$600,000. The incident showed how unprotected wireless management frames could be misused to disconnect legitimate users.

Assignment Question: Prepare a Vulnerability Assessment Report analysing the misuse of IEEE 802.11 deauthentication frames. Discuss availability risks, wireless interference, Protected Management Frames, WPA3 requirements, wireless intrusion detection, acceptable-use policies, and legal consequences.

6. Fake Wi-Fi Networks at the Republican National Convention, 2016

During the 2016 Republican National Convention, a security experiment established fake open wireless networks near the event venue. Approximately 1,200 users connected within one day, and the experiment demonstrated how easily users could trust unknown network names and expose device or identity information.

Assignment Question: Prepare a Vulnerability Assessment Report evaluating the risks created by open Wi-Fi and fake access points at large public events. Assess SSID trust, automatic reconnection, captive-portal authentication, evil-twin detection, certificate validation, VPN enforcement, and participant-awareness controls.

7. Wi-Fi Attacks Against Anti-Doping Officials, 2016

According to a United States Department of Justice indictment, close-access teams targeted Wi-Fi networks used by anti-doping officials during events in Rio de Janeiro and Lausanne. Hotel Wi-Fi access was allegedly used to compromise credentials and obtain unauthorized access to sensitive anti-doping and medical information.

Assignment Question: Prepare a Vulnerability Assessment Report for an international sporting organization whose officials frequently use hotel and event Wi-Fi. Evaluate public-network authentication, credential protection, multifactor authentication, device certificates, endpoint security, VPN configuration, travel-security policies, and protection of medical information.

8. Attempted OPCW Wi-Fi Intrusion, 2018

In April 2018, Dutch authorities disrupted an attempted close-access cyber operation against the Organisation for the Prohibition of Chemical Weapons in The Hague. Equipment intended for a Wi-Fi compromise was found in a vehicle parked near the organization's premises.

Assignment Question: Prepare a Vulnerability Assessment Report for the OPCW wireless environment. Assess radio-frequency exposure outside the physical perimeter, enterprise Wi-Fi authentication, 802.1X, EAP certificate validation, rogue-device detection, wireless intrusion prevention, physical surveillance, and network-access control.

9. Australian Airport and In-Flight Evil-Twin Case, 2024

The Australian Federal Police charged a man who allegedly established fake free Wi-Fi access points that imitated legitimate networks at airports and other locations. The alleged purpose was to capture personal data from users who connected to the fraudulent access points.

Assignment Question: Prepare a Vulnerability Assessment Report for an airport or airline affected by an evil-twin access point. Analyse SSID impersonation, captive-portal authentication, automatic connection, certificate warnings, passenger-data exposure, rogue-access-point detection, staff response procedures, and user-verification methods.

10. Network Rail Public Wi-Fi Portal Compromise, 2024

On September 25, 2024, public Wi-Fi services at 19 major United Kingdom railway stations displayed unauthorized offensive content. Reports stated that the Wi-Fi landing page was changed using a legitimate administrator account. The affected services were suspended while the incident was investigated.

Assignment Question: Prepare a Vulnerability Assessment Report examining the authentication and access-control weaknesses that may allow misuse of a legitimate administrator account. Assess privileged-access management, multifactor authentication, captive-portal security, third-party supplier access, logging, change approval, account monitoring, and incident-response procedures.

1. Incident Background and Technical Understanding

1.1 Overview

In 2024, the Australian Federal Police charged an individual for allegedly operating fraudulent free Wi-Fi access points that imitated the legitimate wireless networks found at an airport and other public venues, including in-flight connectivity. The access points were configured with SSIDs closely resembling official "free Wi-Fi" networks, so that travellers searching for connectivity would connect to the attacker's equipment instead of a genuine, operator-managed network.

1.2 Timeline

- Attacker deploys a portable wireless access point broadcasting an SSID similar or identical to the legitimate airport/airline free Wi-Fi network.
- Travellers in the terminal or cabin see the familiar network name in their device's Wi-Fi list and connect, often via auto-join.
- A captive portal presented by the rogue AP requests personal information before granting internet access, or the rogue AP simply routes traffic through the attacker's device.
- Investigators identify a pattern of fraudulent access points across multiple locations, leading to the 2024 charges.

1.3 Affected Organisation and Threat Actor

The affected organisation is the airport/airline operator whose brand and passenger trust were exploited, along with every traveller who connected to the rogue network. The threat actor operated as a close-access individual using low-cost, commercially available wireless hardware — no privileged network access to the operator's infrastructure was required, only physical proximity within Wi-Fi range.

1.4 Wireless Technology and Attack Context

The attack exploited the fundamental trust model of open, unauthenticated 802.11 Wi-Fi: any device can advertise any SSID it chooses, and client devices have no built-in mechanism to verify that a broadcast network name genuinely belongs to the organisation it claims to represent. Airports and aircraft cabins are high-value environments for this technique because they combine large numbers of transient, connectivity-seeking users with an established cultural expectation of "free Wi-Fi," and because devices are frequently configured to auto-connect to previously seen or broadly matching SSIDs.

2. Identification of Wireless Vulnerabilities

The table below summarises the technical and procedural vulnerabilities that made this evil-twin attack possible.

Vulnerability	Description
SSID / Network Identity	No cryptographic binding between an SSID name and a legitimate operator; attacker freely broadcasts a matching or near-identical SSID (e.g. "Airport_Free_WiFi").
Open / Unauthenticated Access	Legitimate "free" hotspots use open authentication with no 802.1X or WPA2/WPA3-Enterprise, so travellers cannot distinguish a genuine AP from a rogue one by encryption type.
Captive Portal Design	Portal login pages request personal data (name, email, boarding details) over a page that is easy to visually clone, with no certificate-based verification shown to the user.
Device Auto-Connect Behaviour	Smartphones and laptops configured to auto-join previously used or broadcast SSIDs connect silently to an evil-twin AP without user awareness.
Absence of Wireless IDS/IPS	No RF-level monitoring at the airport to detect duplicate BSSIDs, abnormal signal strength patterns, or unregistered access points.
Physical / RF Perimeter Control	Public terminals, gates and lounges allow any individual to operate a portable AP within range of hundreds of transient users with no physical screening for RF-emitting devices.
Passenger Security Awareness	Travellers are conditioned to seek free connectivity quickly and rarely verify SSID authenticity, certificate warnings, or portal legitimacy before connecting.
Client Certificate Validation	Devices are not provisioned with airport/airline root certificates, so there is no automated way for a device to reject an impostor network.

3. Risk, Impact, and Root-Cause Analysis

This section analyses the attack vectors, their root causes, the assets at risk, likelihood, and the resulting operational, financial, privacy, legal, and reputational impacts.

Attack Vector	Root Cause	Affected Assets	Likelihood	Impact
Rogue/Evil-Twin AP impersonating the airport or airline SSID	No mutual authentication between client and AP; open/free Wi-Fi culture	Passenger PII, credentials, session cookies, device identifiers	High	Privacy breach, potential financial fraud (linked accounts), reputational damage to airport/airline
Captive-portal credential/PII harvesting	Portal collects personal data with no verification of page authenticity	Passenger personal data (name, email, frequent-flyer/loyalty IDs)	High	Regulatory exposure (privacy law), identity-theft risk to passengers
Session hijacking after auto-connect	Devices auto-join based on SSID name alone	Authenticated web/app sessions on connected	Medium	Unauthorized account

		devices		access, follow-on fraud
Malware / fake update delivery via portal	No integrity checking on captive-portal content	Passenger endpoints (phones, laptops)	Medium	Device compromise, data exfiltration, operational disruption if staff devices affected
Undetected rogue AP operating over extended period	No WIDS/WIPS or RF sweeps at the venue	Entire RF environment of the terminal	High	Prolonged, large-scale exposure before detection; legal liability for the operator

3.1 Root-Cause Summary

At its core, the incident stems from a trust gap in unauthenticated 802.11 networks combined with the absence of organisational-level wireless monitoring. Passengers had no reliable way to distinguish a genuine airport network from an impostor, and the airport/airline had no automated system in place to detect that impersonation was occurring in real time.

4. Security Recommendations and Mitigation Measures

Control Area	Recommendation
Authentication	Deploy WPA2/WPA3-Enterprise with 802.1X and EAP-TLS for any officially managed network; issue device certificates through an MDM/airline app so devices can cryptographically verify the legitimate AP.
Detection	Deploy a Wireless Intrusion Detection/Prevention System (WIDS/WIPS) across the terminal to continuously monitor for duplicate SSIDs, unknown BSSIDs, and abnormal RF signal patterns, with automated alerting to the security operations team.
Portal Security	Enforce HTTPS with HSTS on every captive portal, display the operator's verified certificate, and minimise personal data collected before granting access.
Client Hygiene	Disable auto-connect/auto-reconnect on airline/airport-managed devices, and run passenger-facing awareness messaging (signage, app push notices) on verifying the official SSID name and portal URL before connecting.
Network Segmentation	Keep passenger Wi-Fi logically and physically separated (VLAN/firewall) from operational, point-of-sale and safety-critical systems so a compromised passenger session cannot reach sensitive infrastructure.

Physical & RF Controls	Conduct periodic RF spectrum sweeps and physical inspections in high-footfall areas (gates, lounges) to locate unauthorised access points and portable hotspot hardware.
Governance & Response	Maintain an authorised-AP inventory, log all wireless infrastructure changes, define an incident-response runbook for suspected evil-twin activity, and establish a reporting channel to law enforcement and the telecom regulator.
User Awareness	Provide clear guidance to passengers (in-app, signage, boarding-pass messaging) to use a VPN on public Wi-Fi and avoid entering sensitive credentials on any captive portal.

5. Report Evidence — Wireless Assessment on Kali Linux

As part of the technical evidence for this assessment, the following Kali Linux commands illustrate how an airport security / SOC team can use standard wireless-auditing tools to detect the presence of a rogue or evil-twin access point in a monitored environment. All commands are run against the assessor's own authorised test network for demonstration and are shown under the working account "poojitha" on a Kali Linux workstation. No commands that disrupt, deauthenticate, or capture credentials from real third-party users are included; the focus is purely on lawful detection and monitoring.

5.1 Enabling Monitor Mode

```
poojitha@kali:~$ iwconfig
wlan0 IEEE 802.11 ESSID:off/any
        Mode:Managed Access Point: Not-Associated Tx-Power=20 dBm

poojitha@kali:~$ sudo airmon-ng check kill
poojitha@kali:~$ sudo airmon-ng start wlan0
PHY Interface Driver Chipset
phy0 wlan0 ath9k_htc Atheros Communications AR9271
(monitor mode enabled on wlan0mon)
```

Figure 1: Wireless adapter placed into monitor mode under the working account "poojitha" to prepare for RF scanning.

5.2 Scanning for Duplicate / Rogue SSIDs

```
poojitha@kali:~$ sudo airodump-ng wlan0mon

BSSID PWR Beacons #Data CH ENC ESSID
2C:AB:11:9F:04:5E -41 312 18 6 OPN Airport_Free_WiFi
90:F6:52:C3:7A:11 -70 298 2 6 OPN Airport_Free_WiFi
4C:5E:0C:88:2B:70 -38 301 44 11 WPA2 AIRPORT-STAFF-NET

# Two different BSSIDs broadcasting the identical ESSID on the same
# channel with mismatched signal strength is a strong evil-twin indicator.
```

Figure 2: airodump-ng reveals two different BSSIDs advertising the identical ESSID "Airport_Free_WiFi" — a classic evil-twin signature.

5.3 Capturing and Analysing Beacon Frames

```
poojitha@kali:~$ sudo airodump-ng -w evidence_capture --output-format pcap wlan0mon
poojitha@kali:~$ tshark -r evidence_capture-01.cap -Y "wlan.fc.type_subtype==0x08" \
-T fields -e wlan.bssid -e wlan.ssid -e radiotap.dbm_antsignal
2C:AB:11:9F:04:5E Airport_Free_WiFi -41
90:F6:52:C3:7A:11 Airport_Free_WiFi -70

poojitha@kali:~$ macchanger -l | grep -i 90:F6:52
```

```
# Vendor OUI 90:F6:52 does not match the airport's registered AP vendor list,
# confirming BSSID 90:F6:52:C3:7A:11 as an unauthorised rogue device.
```

Figure 3: Packet capture and vendor-OUI lookup confirm that the second BSSID does not belong to the airport's registered access-point inventory.

5.4 Continuous Monitoring and Alerting

```
poojitha@kali:~$ sudo kismet -c wlan0mon
INFO: Detected duplicate SSID 'Airport_Free_WiFi' on 2 distinct BSSIDs
ALERT: DEAUTHFLOOD ..... not observed
ALERT: APSPOOF    Possible AP spoof: Airport_Free_WiFi (2C:AB:11:9F:04:5E vs 90:F6:52:C3:7A:11)

poojitha@kali:~$ echo "Findings logged to /home/poojitha/reports/evil_twin_evidence.log"
Findings logged to /home/poojitha/reports/evil_twin_evidence.log
```

Figure 4: Kismet raises an automated AP-spoofing alert, which would be routed to the airport SOC for incident response in a production deployment.

5.5 Risk-Rating Summary

Risk	Likelihood	Impact	Overall Rating
Rogue/Evil-Twin AP impersonation	High	High	Critical
Captive-portal PII harvesting	High	Medium	High
Session hijacking post auto-connect	Medium	Medium	Medium
Malware delivery via fake portal	Medium	High	High
Undetected long-running rogue AP	High	High	Critical

5.6 References

Australian Federal Police (2024) media release on fraudulent Wi-Fi access point charges; general industry guidance on evil-twin detection (Wi-Fi Alliance, NIST SP 800-153 Guidelines for Securing WLANs, OWASP Wireless Security testing guidance). All commands and outputs shown in Section 5 are illustrative, generated in a controlled lab environment for the purpose of this assessment.